

CASE STUDY
CYBERSECURITY (18AMC402T)
DEPARTMENT OF ARTIFICIAL INTELLIGENCE AND MACHINE
LEARNING
IV YEAR / VII SEMSTER

DONE BY:

KISHORE R (927622BAL022)

MONIESH A K (927622BAL026)

VIJAY P J (927622BAL054)

1. Analyze the effectiveness of the existing firewall setup. Would implementing an IPS alongside an application-layer firewall have mitigated the attack? Provide a justified evaluation based on security architecture.

Introduction to Firewall Evaluation:

Evaluating the effectiveness of the existing firewall setup requires an understanding of its architecture, scope, and capabilities in the context of modern cyber threats. Traditional firewall configurations often function primarily at the network and transport layers, filtering traffic based on port numbers, IP addresses, and basic protocol rules. While these controls are foundational, the landscape of attacks has evolved significantly. Attackers no longer rely solely on port scanning or simple unauthorized access; instead, they inject malicious payloads inside legitimate traffic streams, exploit vulnerabilities at the application layer, and adopt stealthy communication methods that bypass signature-based controls. Therefore, assessing the existing firewall setup reveals that although it may perform satisfactorily for baseline filtering, it is insufficient to counter sophisticated, multi-layered attacks.

Limitations of the Existing Firewall Setup:

The primary limitation of the existing firewall infrastructure lies in its inability to inspect deep content within application-layer traffic. A standard Layer 3/4 firewall cannot analyze encrypted HTTP requests, detect SQL injection attempts, or identify malicious scripts embedded within allowed protocols. Most organizations configure firewalls to allow HTTPS, DNS, and web application traffic because these services are essential for daily operations. However, cybercriminals use this same encrypted and permitted traffic to infiltrate systems. Without deep packet inspection, the firewall simply grants

access to these sessions without understanding the content, making it vulnerable to malicious payloads disguised as legitimate communication.

Another major gap is the lack of behavioral analysis. Traditional firewalls cannot detect anomalies such as sudden spikes in outbound traffic, unusual DNS requests, or repeated authentication failures. They also do not correlate events across multiple sessions. This weakness is critical because modern attackers spread their activities across different stages of the kill chain, using subtle movements that would only be detected through behavior-based analysis.

Role of Application-Layer Firewalls in Strengthening Defenses:

Application-layer firewalls, including Web Application Firewalls (WAFs), address these deficiencies. Unlike traditional firewalls, WAFs operate at Layer 7 and inspect the actual content of requests and responses. They can block malicious patterns such as SQL injection payloads, cross-site scripting attempts, and unauthorized API calls. By analyzing cookies, headers, and behavioral patterns, a WAF enforces security based on the context of the application itself.

If an application-layer firewall had been implemented in the scenario under assessment, malicious requests would have undergone deeper scrutiny. The WAF would likely have identified suspicious request structures or abnormal query parameters that deviated from legitimate application behavior. This higher-layer filtering significantly reduces the attack surface and prevents exploitation of application vulnerabilities—a capability absent in basic firewalls.

Contribution of IPS to Proactive Threat Mitigation:

An Intrusion Prevention System (IPS) adds another critical layer of defense by detecting and blocking malicious network activity in real time.

Unlike a firewall, an IPS monitors traffic flows, analyzes packet content, inspects protocol behavior, and correlates anomalies across sessions. IPS solutions use signature-based, anomaly-based, and behavior-based engines to identify threats ranging from known exploits to zero-day anomalies.

For example, if the attack involved port scanning or brute-force login attempts, the IPS would detect abnormal request patterns and automatically block the offending source. If attackers attempted to exploit vulnerabilities through crafted payloads, the IPS would recognize and stop these attempts based on signatures or behavioral irregularities. IPS tools also detect post-compromise activities such as lateral movement, command-and-control traffic, or data exfiltration—stages that a firewall cannot interpret.

Would IPS + Application-Layer Firewall Have Mitigated the Attack:

Considering the gaps identified in the existing firewall setup, combining an IPS with an application-layer firewall would have significantly strengthened the overall security posture. The WAF would filter traffic based on application logic, ensuring that malicious payloads, malformed requests, and unauthorized API interactions were blocked. Simultaneously, the IPS would monitor network traffic patterns, detect anomalies, enforce behavioral checks, and prevent exploit attempts targeting software vulnerabilities.

This layered defense model—often referred to as “Defense in Depth”—ensures that even if one control fails, others remain to contain or prevent the attack. An attacker would need to bypass both signature-based detection and application-layer inspection, which is far more challenging. Therefore, the combined use of IPS and WAF would highly likely have mitigated or even fully prevented the attack by providing protection at multiple layers of the security stack.

Conclusion:

The existing firewall setup was insufficient because it relied heavily on basic packet filtering without advanced inspection or behavioral analysis. Implementing an IPS alongside an application-layer firewall would have created a more resilient and layered security architecture capable of identifying malicious traffic early, blocking application-specific threats, and correlating suspicious activities across sessions. This combination would have significantly reduced the likelihood of compromise and is essential for modern cyber defense strategies.

2. Analyze the compliance and security risks of relying solely on an IPS without a firewall. Should a layered defense strategy be adopted? Justify your evaluation using compliance and threat mitigation perspectives.

Introduction: The Gaps in IPS-Only Architectures:

An Intrusion Prevention System (IPS) is a powerful security tool, but it was never designed to replace a firewall. Firewalls represent the most fundamental layer of perimeter defense, preventing unauthorized access while controlling traffic based on defined policies. IPS, on the other hand, performs deep inspection and behavioral analysis. When an organization relies solely on IPS without a firewall, it eliminates the boundary filtration necessary to protect internal networks. This creates an unstructured and risky security environment where malicious users can reach critical systems without basic filtering.

Compliance Risks Due to Missing Firewalls:

Most major regulatory standards mandate firewalls explicitly. For example:

- **PCI-DSS Requirement 1:** “Install and maintain a firewall configuration to protect cardholder data.”
- **HIPAA Security Rule:** Requires mechanisms to protect data in motion using perimeter safeguards.

If an organization removes the firewall and depends only on IPS, it becomes instantly non-compliant. Auditors typically reject IPS-only architectures because they lack essential components such as static access rules, default-deny policies, and fixed segmentation boundaries. Non-compliance exposes organizations to fines, legal challenges, revocation of certifications, mandatory audits, and in some cases, suspension from operating in regulated industries.

Security Risks in IPS-Only Environments:

An IPS by itself does not restrict access; it only analyzes and blocks suspicious traffic. Without a firewall enforcing strict ingress and egress rules, attackers can freely probe the network. Open ports, unrestricted IP ranges, and unfiltered protocol access create numerous entry points.

Furthermore, IPS devices rely on traffic visibility. If attackers use encrypted payloads, tunneling protocols, or obfuscation techniques, the IPS may not fully detect the threat. A firewall would normally restrict such traffic or decrypt it for inspection. Without this initial filtering layer, IPS becomes overwhelmed and ineffective.

Another critical security weakness is the lack of segmentation. Firewalls divide networks into separate zones such as DMZ, internal network, and guest network. Without segmentation, attackers can move laterally once a single system is compromised. IPS cannot prevent this movement because it does not enforce structural boundaries.

Necessity of Layered Defense: Justification:

Cybersecurity best practices strongly recommend a layered defense strategy based on the principle that no single control can stop all threats. Combining a firewall and IPS results in:

- Perimeter filtering (firewall)
- Deep packet and behavior inspection (IPS)
- Access control enforcement
- Segmentation
- Anomaly detection
- Zero-day identification

This combination ensures that organizations meet compliance requirements while remaining protected against diverse attack vectors.

Conclusion:

Relying solely on an IPS undermines both compliance and security, exposing the organization to regulatory violations and an expanded attack surface. A layered strategy that integrates firewalls, IPS, and other complementary tools is essential for achieving a resilient, compliant, and secure network environment.

3. Analyze the effectiveness of existing wireless security policies and recommend changes to reduce the risk of such attacks. Justify your recommendations with reference to tool capabilities and network vulnerabilities.

Introduction:

Wireless networks form a critical backbone for modern organizations, especially those operating in hybrid or mobile environments. However, the flexibility provided by wireless connectivity also introduces significant security challenges—ranging from unauthorized access to sophisticated man-in-the-middle (MITM) attacks. To evaluate the effectiveness of existing wireless security policies, it is essential to examine whether the implemented standards, authentication mechanisms, monitoring tools, and administrative controls are capable of resisting real-world threat vectors. The goal is not only to review the technical strengths and weaknesses but also to determine whether the overall wireless governance framework aligns with best practices in network security.

Evaluation of Existing Wireless Security Policies:

Many organizations still rely on older Wi-Fi encryption standards such as **WPA2-PSK**, which, although widely used, is vulnerable to password cracking, handshake capture, and dictionary attacks. If the existing policy still allows weaker encryption types or shared passwords, it exposes the entire wireless infrastructure to unauthorized access. In some environments, devices may continue to support WEP or open networks for guest access, which further weakens the overall security posture. The absence of **802.1X authentication** also indicates weak identity verification, making it easier for attackers to impersonate legitimate users.

Lack of Network Segmentation:

A common weakness is the presence of a **single flat wireless network** shared by employees, IoT devices, printers, and guest users. This policy significantly increases lateral movement opportunities for attackers. If an attacker compromises one access point or endpoint, they can pivot across the

network without encountering internal firewalls or VLAN separation. The absence of segmentation can also overwhelm administrators, making it difficult to enforce differentiated access controls for sensitive departments such as finance or HR.

Inadequate Monitoring and Intrusion Detection:

Many wireless security policies fail to integrate **Wireless Intrusion Detection Systems (WIDS)** or **Wireless Intrusion Prevention Systems (WIPS)**. Without these, attacks such as rogue access points, deauthentication storms, SSID spoofing, and evil-twin attacks may go unnoticed. Additionally, insufficient logging practices hinder forensic analysis after an incident. If logs from access points, authentication servers, and controllers are not centralized, the organization loses visibility into suspicious activity patterns.

Weak Password Management and Access Controls:

If users share Wi-Fi passwords or if the organization does not enforce periodic password rotation, stale credentials may circulate widely—even outside the organization. This makes brute-force attacks more successful, especially against poorly secured PSK networks. Similarly, policies that fail to address device-level access control allow personal mobile devices to connect without security vetting, increasing the risk of malware infiltration.

Hardware-Level Vulnerabilities and Outdated Firmware:

Wireless routers and access points require routine firmware updates to patch vulnerabilities related to chipsets, encryption modules, and management interfaces. If the existing policy does not mandate scheduled firmware updates or device hardening (disabling WPS, remote administration, or default credentials), adversaries can exploit these weaknesses.

Network Vulnerabilities Contributing to Attacks:

Attackers often deploy rogue APs mimicking legitimate SSIDs. If the organization lacks WIDS/WIPS or fails to conduct routine RF spectrum scans, such devices remain undetected. Employees may unknowingly connect to these malicious APs, exposing their credentials and internal traffic.

MAC Address Spoofing:

MAC filtering alone is ineffective because attackers can easily spoof MAC addresses using readily available tools. If policies rely on MAC filtering as a primary authentication method, the network becomes vulnerable to masquerading attacks.

Deauthentication (Deauth) Attacks:

Many wireless networks are vulnerable to **deauth packet floods**, where attackers disconnect users and force them to reconnect via a malicious access point. Without 802.11w Protected Management Frames (PMF), these attacks are highly successful.

Weak Guest Network Controls:

Guest networks may not have bandwidth limits, web filtering, or isolation enabled. Attackers can use them as entry points to scan internal subnets or launch phishing attacks.

Recommended Improvements to Wireless Security Policies:

Migrating to **WPA3-Enterprise** significantly increases protection through:

- Simultaneous Authentication of Equals (SAE)
- Stronger encryption

- Per-user authentication through RADIUS or Active Directory
This eliminates shared passwords and provides device-specific auditing.

Implement Strong Network Segmentation and VLAN Security:

Segmentation ensures that even if attackers compromise the wireless network, they cannot escalate privileges. This includes:

- Separate VLANs for employees, guests, IoT devices
- Internal firewalls between critical segments
- Role-based access control (RBAC)

Deploy WIDS/WIPS for Continuous Monitoring:

Tools such as **Cisco Prime, Aruba AirWave, AirMagnet, Ekahau**, and cloud-based WIPS can:

- Detect rogue APs
- Block unauthorized connections
- Identify deauth attacks
- Locate physical devices through triangulation

These tools transform the wireless network from a passive structure to an actively monitored environment.

Enforce Device Compliance and NAC Policies:

Network Access Control (NAC) ensures that only secure, updated devices can connect. Policies should enforce:

- OS updates
- Antivirus presence

- Configuration compliance
- Restricted access for unmanaged devices

Solutions like Cisco ISE, Aruba ClearPass, or FortiNAC integrate seamlessly with wireless controllers.

Strengthen Password and Key Management Procedures:

Policies should mandate:

- No shared Wi-Fi passwords
- Automatic key rotation
- Multi-factor authentication for administrative access
- Certificate-based authentication for corporate devices

Enable Protected Management Frames (PMF):

802.11w PMF:

- Prevents deauth/disassoc attacks
- Protects management frames
- Enhances AP-client communication integrity

Regular Wireless Audits and Penetration Testing:

Annual or quarterly wireless security audits using tools like:

- Kali Linux WLAN Suite
- Kismet
- Aircrack-ng

Conclusion:

A strong wireless security policy must extend beyond basic encryption and access control. It should combine advanced authentication standards, active monitoring, segmentation, and consistent device governance. The shortcomings observed—such as outdated authentication, lack of WIDS/WIPS, weak password practices, and minimal segmentation—expose the wireless network to multiple real-world attacks. Implementing the recommended improvements, such as WPA3 Enterprise, NAC, PMF, and robust monitoring, will significantly strengthen the wireless infrastructure and reduce risks from evolving threats. Ultimately, wireless security is not a one-time configuration but a continuously managed and evaluated component of organizational cybersecurity.
